

marshmallows — a secure mesh for IoT

A whitepaper · TrustSentinel · v1.0 (2026)

Álvaro López — *security architect (CISSP)* Recognised at the **INCIBE National Cybersecurity Competition 2019** — a lightweight-cryptography secure-mesh architecture for IoT.

Abstract

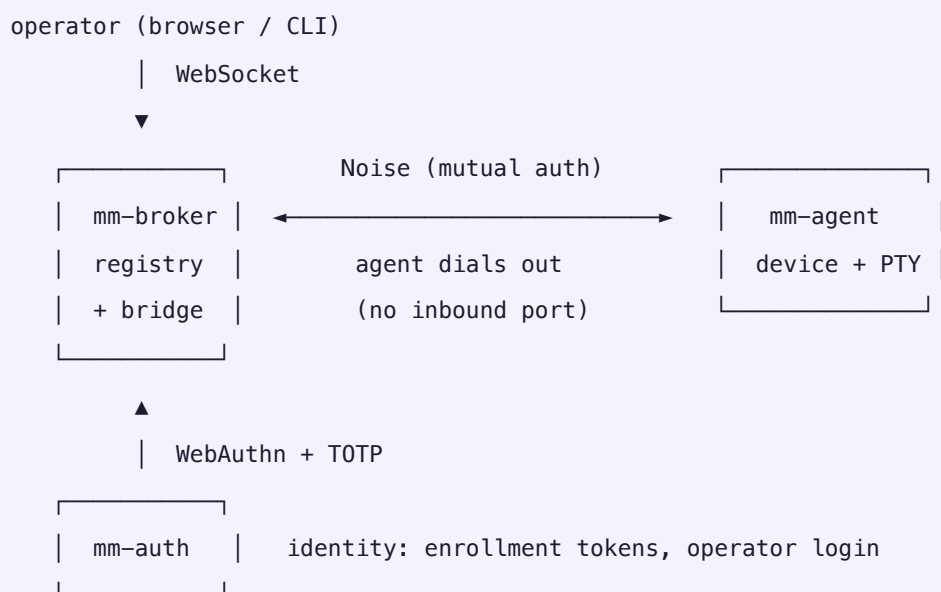
marshmallows is a self-hostable platform for managing and reaching IoT and edge devices securely, wherever they sit on the network. Devices attach to a **mini-cloud** coordinated by a **broker** and become reachable by a stable, human-friendly name — from a terminal or a browser — with **no inbound port** opened on the device. Every device link is established over the **Noise Protocol Framework** (Curve25519 / ChaCha20-Poly1305 / BLAKE2b), avoiding the certificate and key overhead of TLS on constrained hardware. Operator access is passwordless and phishing-resistant (WebAuthn) with an optional TOTP second factor.

1. Problem

Edge and IoT fleets are hard to reach safely: devices roam across NATs and changing IPs, opening inbound ports is a liability, and TLS PKI is heavy for constrained hardware. Operators still need day-to-day shell access to any device, from anywhere, without tracking addresses or punching holes in firewalls.

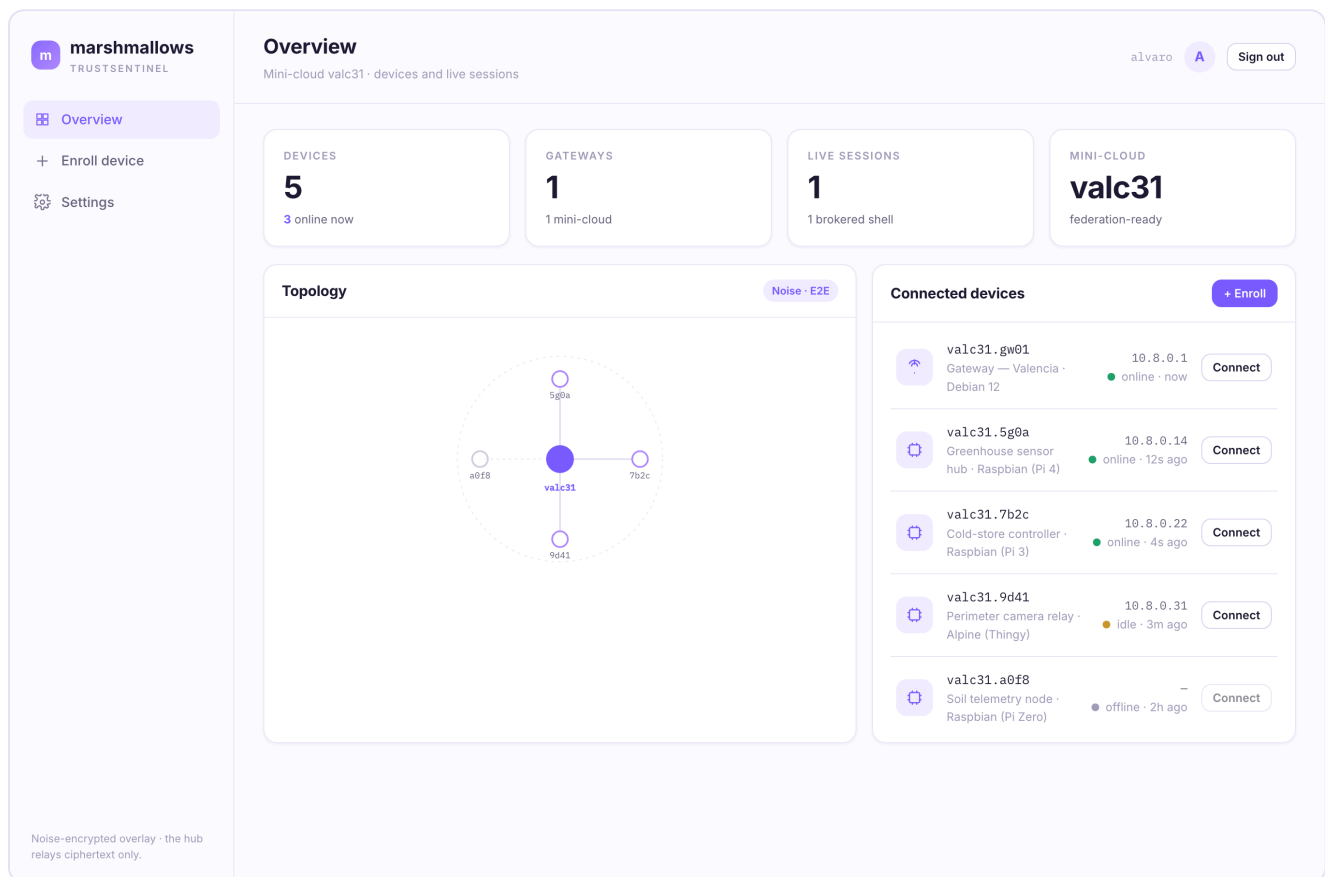
2. Architecture

A deployment is a **mini-cloud** (`cloud_id`) with three services and any number of device agents:



- **mm-broker** — the coordinator. Agents attach to it over a mutually authenticated Noise session; it keeps an in-memory registry (exposed as `/devices.json`) and **bridges** an operator's terminal to the target agent, multiplexing every session over the agent's single encrypted channel.
- **mm-agent** — runs on the device. It **pins the broker's static key** (Noise IK), enrolls once with a **single-use token**, then serves PTY shells on demand. It only ever *dials out*, so the device needs no open inbound port.
- **mm-auth** — the identity service: it mints enrollment tokens (verified by the broker, single-use) and authenticates operators with WebAuthn + TOTP.
- **web** — a dashboard for device management and an in-browser terminal.

Human-friendly identifiers. Every element gets a dotted alias scoped by cloud and device — `cloud_id.device_id[.service_id]`, e.g. `valc31.5g0a` or `valc31.5g0a.ssh` — so operators reach a device by name, never by a volatile IP.



3. Security model

- **Transport.** Agent ↔ broker runs the Noise **IK** pattern: the agent pins the broker's static public key up front (no trust in first contact, no MITM), and both parties authenticate by static key. The suite is Curve25519 + ChaCha20-Poly1305 + BLAKE2b — lightweight enough for constrained devices.

- **Enrollment.** A device joins with a **single-use token** minted by mm-auth; the broker verifies it with mm-auth and consumes it. Device identity is a persistent Noise keypair generated on first run.
- **Least exposure.** Agents dial out; there is no listening shell port on the device. The shell channel is Noise-encrypted (the 2019 prototype relayed it in plaintext — fixed in v1.0).
- **Operator identity.** Passwordless WebAuthn (security keys / platform authenticators, U2F/FIDO) with an optional TOTP second factor. No shared passwords.
- **Trust boundary (v1.0).** The browser ↔ broker leg is protected by the operator session over TLS (a reverse proxy in production); the broker bridges it to the agent's Noise channel. The broker is therefore a trusted relay for the terminal stream. A future browser client (Go compiled to WebAssembly, as in [stk](#)) can extend Noise all the way into the browser for full end-to-end confidentiality.

4. Deployment

The whole platform runs from one Docker Compose file (dashboard, broker, a device agent, and identity). An agent ships inside a device image (a customised Debian/Raspberry-Pi build, or a container) and needs only outbound reachability to the broker. Mini-clouds are designed to **federate**: brokers can associate so devices become mutually reachable across deployments, subject to each operator's policy.

5. Roadmap

- Browser-to-agent end-to-end encryption via a WebAssembly Noise client.
- Federation between mini-clouds (cross-broker device visibility and policy).
- Blockchain-anchored device identity (DIDs), shared with the [netso](#) platform.
- Fine-grained, per-device access policy and audit.

6. Recognition

INCIBE National Cybersecurity Competition 2019 — recognised as a lightweight-cryptography secure-mesh architecture for IoT. Continued and modernised under TrustSentinel.

References

- Noise Protocol Framework — <<https://noiseprotocol.org/>>
- WebAuthn (W3C Web Authentication) — <<https://www.w3.org/TR/webauthn-2/>>
- TrustSentinel — <<https://trustsentinel.eu>>